

Understanding the scope of a Vulnerability Disclosure Program is the difference between being a professional pentester and being the target of an FBI investigation. As we have explored over the course of these memorandums, authorization is the dividing line between research and intrusion. A professional cybersecurity researcher should understand the vulnerability disclosure program, lest their work be treated as unauthorized access or hostile behavior. In this report, I will cover the basics of a good vulnerability disclosure policy, the commitment DoW has made in regards to cybersecurity researcher legal protections, and the technical definitions as applied by the DoW towards findings.

As we are aware, a vulnerability disclosure program (VDP) is designed to help the parent organizations assist and reward good cybersecurity research. General cybersecurity hygiene thus isn't sufficient without a method to document and remedy issues brought forth. Utilized correctly, VDPs are the best practices introducing structured method of cybersecurity vulnerabilities. I liken it to transforming reactive patching into a compliance accelerating mechanism. For this report, I referred to the Officer of Inspector General's 2025 audit report as well as the DoD Cyber Crime Center 2022 Annual Report on the Vulnerability Disclosure program. Cyber vulnerabilities are often reported in waves, and the applicability of VDP allows valuable insight to be drawn via crowdsourced reports from either volunteer, defense industrial base companies, or even academic subject matter experts.

Discussed earlier, the difference between being a cybersecurity professional and becoming a target of the FBI is authorization. The VDP has several areas that are out of scope. Specifically, VDP has asked researchers to consider realistic attack scenarios as well as the total security impact of researcher behavior. The safe-harbor language protects good-faith researchers who follow those rules. The out-of-scope language covers theoretical vulnerabilities that might require physical access to a secured device, open redirects from faulty website configurations, and the hazardous testing involving social engineering attacks. Overall, DoW shows "Commitment" by dedicating working with researchers in good faith. A good example is the Log4J crisis in December 2021 thru January 2022 where VDP received multiple submissions for the CVE-2021-44228 due to apache running on many common services, applications, and framework. As a result, a researcher following the restrictions and staying scope was rewarded. Additionally, DoW has been quoted on record to sanction authorized activities within VDP. Additionally, any third party defense contractor bringing legal action over researcher activity that complied with the policy has legal protection by DoW. Thus, this is how safe harbor is provided.

The "Out of Scope" section reminds researchers when one's activity is no longer authorized. If a system, domain, or technique is out of scope, the researcher should not test it unless the VDP team explicitly confirms that it is allowed. Here are three specific examples as I interpreted the scope defined under the VDP.

First, denial-of-service activity is forbidden. Researchers should not perform DoS, DDoS, stress testing, resource exhaustion, or other tests that impair access to a DoD system. Under CIA triad principle, availability is a hard requirement unless specific sanction has been granted given how the systems tested are vital to national security. Second, social engineering is forbidden. Attacks that attempt to access secured facilities under forged credentials, circumvent access controls, or impersonate personnel is directly a crime under 18 U.S. Code § 912. Traditional red team activities involving social engineering against people, buildings, and operational security are explicitly not covered by the VDP. Third, attacks against physical facilities are forbidden. The VDP is aimed at publicly accessible information systems, web properties, and data owned, operated, or controlled by DoD. As a result, the attack on physical facilities are clearly not covered by VDP. If a vulnerability appears to involve physical access controls, cybersecurity researchers should report it through access control vendor's disclosure policy.

As administered, VDP has terms and conditions on publicly accessible information system followed by reporting vulnerabilities. As such, a report is separated into valid finding, duplicate finding, and informational finding. A valid finding is an in-scope, reproducible vulnerability that demonstrates a real security impact. This is typically defined as a valid report pinpointing the affected asset, describes the weakness via MITRE framework, explains the impact on systems, and provides enough evidence for the VDP team to reproduce or verify the issue. Once validated, the report can be forwarded to the relevant DoW system owner for remediation. Meanwhile, the VDP has listed a duplicate finding as a real vulnerability, but one already reported or is otherwise known to the DoD. This distinction matters due to a bulk of reports about the same exposed service, misconfiguration, or application flaw after the CVE, KEV, and CVSS is reported. A duplicate can still be technically accurate, but the VDP can only reward one report at a time. An informational finding is a report while accurate or useful, it does not constitute a security vulnerability. This category of informational finding thus include observations lacking demonstrated impact, security behavior that is already known, and accepted, non-applicable configuration details. Informational reports are different from valid findings because they do not give the system owner a clear, actionable vulnerability to remediate.

All in all, the DoW VDP is a formal agreement between the government and the security-research community providing a detailed scope, safe harbor, and guidance on how to safeguard national security. By giving researchers a way to help defend public-facing DoW systems, DoW thus receive and transform vulnerability before adversaries exploit it. The agreement thus works as all partners now understand the boundaries. For researchers, the key distinction is simple: get authorization. Good intentions do not excuse testing out of scope. A professional reads the VDP, stays inside scope, documents carefully, and reports promptly to the DoW Vulnerability Disclosure Program.